

RMF COMMANDER

Cloud Hosting & eMASS API Integration Requirements

Leadership Review and Sponsorship Package

Document Type	Cloud Hosting & eMASS API Integration Requirements
Version	1.0 — For Leadership Review
Date	22 May 2026
Prepared By	LEO CHRISTIE, NH-III, Information System Security Manager
Organization	Air Force Services Center, VTOS / Cybersecurity Division, JBSA-Lackland, TX 78236
Submitted To	FRANCISCO SALGUERO, SES, NAFI Authorizing Official, USAF HAF AF/A1X
Classification	UNCLASSIFIED
Reference	RMF Commander PRD v1.0 · eMASS API Justification Memo · DISA Cloud Computing SRG

This document is accompanied by the RMF Commander interactive prototype (**rmf-commander-final.html**). Open the HTML file in any browser to review the full operator console and AI Documentation Assistant.

1. Executive Summary

RMF Commander is an AI-assisted mobile and web platform that gives authorized RMF personnel secure, read-only visibility into their portfolio of systems — ATO timelines, POA&M risk, control posture, vulnerability awareness, and documentation drafting support. The AI layer assists; it does not decide, and no changes can be made to any system through the platform.

This package addresses two specific questions from leadership: what is required to host RMF Commander in an authorized cloud environment, and what is required to connect it to eMASS to pull portfolio data. Both are answered below in terms of the technical requirements, the access approval process, and the compliance gates that must be cleared before production use.

The companion HTML file (rmf-commander-final.html) in this package is an interactive prototype of the operator console. Open it in any browser to review the portfolio dashboard, system detail view, and AI Documentation Assistant with the human-approval gate in action.

2. Cloud Hosting Requirements

2.1 Authorized Cloud Platform

RMF Commander must operate inside a DoD-authorized cloud environment at Impact Level 4 (IL4). IL4 covers Controlled Unclassified Information (CUI), which includes RMF portfolio data, POA&M content, and control implementation details. No classified data is in scope for the pilot or initial operating capability.

Azure Government holds a DISA Provisional Authorization (PA) at IL5, which covers IL4 workloads. For an Air Force organization already operating in the Microsoft ecosystem (M365 GCC-High, Entra ID), Azure Government is the natural platform fit, avoiding the additional complexity of cross-platform identity federation. AWS GovCloud also holds an IL5 PA and is a valid alternative.

2.2 Infrastructure Requirements

The following components are required in the cloud tenant. Each must be confirmed against the DISA Cloud Computing SRG IL4 Approved Products List before deployment, as not every Azure Government service is authorized at IL4.

Component	Requirement
Cloud Tenant	Air Force or DoD-owned Azure Government tenant. Use an existing AFSVC tenant or provision a new one under the AF Enterprise Licensing Agreement.
Identity Service	Entra ID Government with CAC/PIV federation via AD FS or a Purebred-compatible identity provider. All user authentications must trace to a DoD PKI credential.
API Proxy / Gateway	Azure API Management (Government tier). The client application must never communicate directly with eMASS. The cloud backend mediates all eMASS service calls.
Secrets Management	Azure Key Vault. eMASS API credentials, service certificates, and JWT signing keys are stored here and retrieved at runtime via Managed Identity — never in code or config files.
Compute / Runtime	Azure App Service (Government), Azure Container Apps, or AKS Government. All services require STIG compliance documentation before ATO.
Logging / SIEM	Azure Sentinel (Government) or an authorized Splunk deployment. All API calls, AI prompts, outputs, and human approvals must be logged for at least 1 year.
Transport Security	TLS 1.3 minimum for all client-to-backend traffic. Mutual TLS (mTLS) is required for all backend-to-eMASS communication.
Data Persistence	No eMASS data persists on the client device. Session data held in memory only. Wiped after 15-minute JWT expiry or 5-minute background timeout.

2.3 STIG Compliance

Every component of the hosting stack requires a documented STIG review before the authorization package can be submitted. The applicable STIGs for RMF Commander are:

- DISA Web Application STIG (web operator console)
- DISA Mobile Application STIG (iOS / Android app)
- DISA Azure Cloud Foundation STIG (tenant baseline)
- DISA Container Platform STIG (if containerized deployment)
- DISA Application Security and Development STIG (backend services)

STIG findings must be remediated or formally risk accepted. Open the CAT I findings block ATO submission.

3. eMASS API Integration Requirements

3.1 API Overview

DISA operates the eMASS REST API as an OpenAPI 3.0.3-compliant service. MITRE maintains the public API specification and open-source client libraries (emass_client) with auto-generated SDKs for Python, Ruby, and TypeScript/Axios. The specification is publicly available at https://mitre.github.io/emass_client/docs/redoc/.

The API provides read and write access to eMASS system records, POA&M items, controls, test results, artifacts, and milestones. RMF Commander uses read-only access only during the pilot. Write-back, artifact submission, and operational authorization decisions remain exclusively in eMASS and with authorized personnel.

3.2 Authentication and API Key Process

Every eMASS API call requires two request headers: api-key and user-uid. The API key is obtained by submitting a POST request to /api/api-key with a valid DoD PKI certificate. For the RMF Commander backend service account, that certificate must be either a DoD system/application certificate issued through an AF PKI sponsor or a user certificate scoped to the service account identity.

The process: your eMASS administrator provisions the service account in eMASS and assigns the appropriate read-only role scope. You call the registration endpoint with the certificate to obtain the API key. That key is stored in Azure Key Vault immediately — it never appears in application code, environment variables, or configuration files. The backend retrieves it at runtime via Managed Identity.

The mTLS requirement means the backend service also presents a client certificate on every outbound connection to eMASS, in addition to the API-key header. Azure API Management can hold and present this certificate automatically.

3.3 Read Endpoints Required for RMF Commander

The following endpoints provide all data needed for the portfolio dashboard, alert engine, system detail view, and AI Documentation Assistant grounding. All calls are GET (read-only) during the pilot.

Method	Endpoint	Purpose for RMF Commander
GET	/api/systems	List all systems in role scope. Drives portfolio dashboard and system cards.
GET	/api/systems/{systemId}	Full system record — ATO/IATT/expired status, ownership,

Method	Endpoint	Purpose for RMF Commander
		categorization, and boundary. Drives system detail view.
GET	/api/systems/{systemId}/controls	Control posture per system — implementation status, findings, evidence links. Drives the controls tab and posture KPIs.
GET	/api/systems/{systemId}/poams	All POA&M items — severity, milestone dates, status, ownership. Core data for the POA&M feed and 90/60/30-day alert engine.
GET	/api/systems/{systemId}/milestones/{poamId}	Milestone detail for a specific POA&M item. Required for slip-detection alerts.
GET	/api/systems/{systemId}/test-results	Assessment procedure results and STIG findings. Feeds scan freshness and CAT I/II/III counts.
GET	/api/systems/{systemId}/artifacts	Artifact metadata (not file content). Used by the briefing generator to list available evidence.
POST	/api/api-key	One-time registration only. Exchanges a valid DoD PKI certificate for the api-key credential stored in Key Vault.

3.4 Access Approval Process

API access provisioning for the Air Force eMASS instance is handled by the eMASS program office for your MAJCOM. The eMASS API Justification Memorandum (included in the pilot proposal package) is the correct artifact to initiate this request. Submit it to your eMASS system administrator alongside a formal help desk ticket requesting sandbox and test API credentials for the RMF Commander pilot tenant registration.

The current memo correctly scopes the request to test/sandbox provisioning only. Production eMASS API access is a separate approval that requires AO sign-off after RMF Commander achieves its own IATT or ATO. Do not conflate the two gates; premature production integration will create an authorization problem before the pilot concludes.

4. Required Architecture Pattern

The eMASS API memo establishes the core constraint: the client application never communicates directly with eMASS. Cloud backend is the only service that holds eMASS credentials and proxies all calls. This is enforced at the network layer, not only by convention.

User Device MDM-enrolled CAC/PIV auth No data at rest	Azure Government IL4 Cloud Boundary RMF Commander Backend (API Proxy) → Azure Key Vault → Entra ID Azure Sentinel (Audit Log) • AI/RAG Layer (IL4 boundary-contained) No IL4 data leaves this boundary for AI processing	eMASS Read-only API mTLS only Pilot: sandbox
--	--	---

TLS 1.3 ↔ (client to backend) | mTLS ↔ (backend to eMASS)

5. Compliance Gates Before Production

The sequence matters. Production use requires clearing the following gates in rough order. Parallel work is possible on items 2 through 4.

#	Gate	Action Required
1	Cloud Tenant	Identify existing AFSVC Azure Government tenant or provision a new one. Confirm IL4 service list for planned components.
2	eMASS Registration	Register RMF Commander as a system in eMASS. Required before any API access request can be approved. Submit the eMASS API Justification Memo to obtain sandbox credentials.
3	SCTM Development	Build the Security Controls Traceability Matrix (SCTM) against NIST SP 800-53 Rev 5 at the MODERATE baseline. Document inherited controls from the cloud platform.
4	Backend Build	Implement the API proxy, identity federation, Key Vault integration, logging pipeline, and session management per PRD NFRs.
5	STIG Compliance	Run and document STIG checklists for all components. Remediate or formally risk-accept all findings. Open CAT I findings block submission.
6	IATT	Submit for an Interim Authority to Test (IATT) from the AO to allow testing with real (but scoped) eMASS data. Required before sandbox-to-production API migration.
7	Penetration Test	DISA-approved pen test or AF red team engagement against the full application stack. Required before ATO package submission.
8	ATO Package	Assemble SSP, SAP, SAR, POA&M, and authorization boundary documentation in eMASS. Submit to AO for authorization decision.
9	Production API Access	With ATO in hand, submit a separate API access request for production eMASS credentials. This is a distinct approval from the sandbox request.

6. Recommended Immediate Actions

Given the current state of the 90-day pilot (Day 41), the following four actions should begin in parallel:

1. Register RMF Commander in eMASS as a new system record. This is Gate 2 and everything else blocks on it.
2. Submit the eMASS API Justification Memo to your MAJCOM eMASS administrator requesting sandbox/test API credentials for the pilot.
3. Identify or provision the Azure Government IL4 tenant and confirm which services are on the DISA-authorized product list for your planned stack.
4. Begin the SCTM at the MODERATE baseline. Inherited cloud controls reduce the surface considerably — document what Azure Government already covers before assessing what is unique to RMF Commander.

7. References

- RMF Commander Product Requirements Document (PRD) v1.0 — 22 May 2026
- RMF Commander eMASS API Access Justification Memorandum v1.0 — 22 May 2026
- RMF Commander Concept Paper v1.0 — 22 May 2026
- DISA Cloud Computing Security Requirements Guide (SRG) v1.0 r3
- NIST SP 800-53 Rev 5 — Security and Privacy Controls for Information Systems and Organizations
- NIST AI RMF 1.0 — AI Risk Management Framework
- eMASS REST API Specification (OpenAPI 3.0.3) — MITRE emass_client:
https://mitre.github.io/emass_client/docs/redoc/
- DISA Mobile Application STIG
- DISA Web Application STIG
- Azure Government DoD IL4/IL5 Overview — Microsoft Learn

Point of Contact

LEO CHRISTIE | NH-III, Information System Security Manager

Air Force Services Center, VTOS / Cybersecurity Division | JBSA-Lackland, Texas 78236